

Security Review

Cantina Managed

SKY: AVALANCHE LZ RE-ENABLING

Cantina Managed review by:

Christoph Michel, Lead Security Researcher

M4rio.eth, Lead Security Researcher



September 4, 2026



Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
3	Findings	4
3.1	Informational	4
3.1.1	<code>migrateAvax</code> opens the L1 OFT before the Avalanche adapter can mint	4
3.1.2	Minor issues, Typos & Documentation	4



1 Introduction

1.1 About Cantina

Cantina is a security platform that pairs a world-class network of security researchers with agentic AI to help teams building onchain find and fix real risk. Through managed reviews, competitions, and bounties, Cantina secures protocols before vulnerabilities can be exploited.

Learn more at cantina.security

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).



2 Security Review Summary

From Aug 19th to Aug 21st the Cantina team conducted a review of [lz-init-lib](#) on commit hash [e717ef6c](#). The team identified a total of **2** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	2	1	1
Total	2	1	1

The Cantina Managed team reviewed Sky's [lz-init-lib](#) holistically on commit hash [70d6e028](#) and concluded that all findings were addressed and no new vulnerabilities were identified.



3 Findings

3.1 Informational

3.1.1 `migrateAvax` opens the L1 OFT before the Avalanche adapter can mint

Severity: Informational.

Context: `LZAvaxMigrationInit.sol#L156`.

Description: `migrateAvax` emits the Avalanche half first (`LZAvaxMigrationInit.sol#L140-L147`), then in the same transaction activates the new Ethereum lockbox, moves the USDS backing, and publishes it on the chainlog:

```
LZInit.activateOft(m.usds.oft, AVAX_EID, m.usds.cfg, m.usds.rateLimits, ...);
LZInit.updateGlobalRateLimits(m.usds.oft, m.usdsGlobalLimits);
// move AVAX_USDS_BACKING into m.usds.oft
chainlog.setAddress("USDS_OFT", m.usds.oft);
```

(`LZAvaxMigrationInit.sol#L156-L174`).

`activateOft` writes the supplied per-eid buckets. `updateGlobalRateLimits` writes the sentinel cap (`LZInit.sol#L227-L254`). The V2 lockbox `send` takes `min(per-eid outbound, sentinel outbound)` and locks the tokens:

```
_checkAndUpdateRateLimit(_dstEid, amountReceivedLD, RateLimitDirection.Outbound);
_checkAndUpdateRateLimit(SENTINEL_EID, amountReceivedLD,
    ↳ RateLimitDirection.Outbound);
innerToken.safeTransferFrom(_from, address(this), amountSentLD);
```

If both outbound buckets are nonzero, any user can `send` on the new lockbox. Tokens lock on L1.

The Avalanche adapter is still waiting on `migrateAvaxRemote` (`LZAvaxMigrationInit.sol#L235-L243`). That call is what:

1. Sets inbound limits (`activateOft`).
2. Grants the new adapter the USDS mint ward (`TokenLike(AVAX_USDS).rely(avaxUsds.oft)`).

Until it lands, `_credit` cannot mint:

```
_checkAndUpdateRateLimit(_srcEid, _amountLD, RateLimitDirection.Inbound);
IMintBurnVoidReturn(token()).mint(_to, _amountLD);
```

Inbound capacity is still 0 and `wards(newAvaxOft) == 0`, so destination `lzReceive` reverts. The L1 `send` already succeeded. After the remote half executes, the packet can be retried.

Same shape for sUSDS at `LZAvaxMigrationInit.sol#L182-L186`. Zero on either outbound bucket keeps `send` closed.

Recommendation: Document that premature transfers can lock on Ethereum and fail on Avalanche. Publish the exact LayerZero retry procedure once migration completes. During cutover, disable every path that could make users bridge.

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.1.2 Minor issues, Typos & Documentation

Severity: Informational.

Context: See each case below.

Description:



1. [LZInit.sol#L123](#): The current interface does not clearly distinguish shared adapter functions from L1-only functionality. Define `L10FTAdapterLike` is `OFTAdapterLike` and declare only `SENTINE L_EID()` in the L1-specific interface.
2. [LZAvaxMigrationInit.t.sol#L80](#): The test sets `OPTIONS_GAS` to `129488`, although the referenced `0x1fbd0` equals `130_000` which is what the currently configured live options use.

[illegible]

3. [LZAvaxMigrationInit.sol#L203](#): The function is explicitly not intended for internal calls but is declared `public`. Change its visibility to `external`.
4. [LZAvaxMigrationInit.sol#L130](#): The current role check does not validate the effective ACL and assumes no denylist (and that configuration is supposed to use an allowlist, not be open to all). Consider using `ccip.hasAcl(govSender)` instead.

Recommendation: Consider fixing the above issues.

Sky:

- 1. No longer applicable as of [sky-oapp-oft#48](#): SENTINEL_EID moved from SkyOFTAdapter up to SkyRateLimiter, so both adapters expose it and there is nothing L1-specific left in `OFTAdapterLike` to split out.
- 2. And 3. Handled as of commit [70d6e028](#).
- 4. Acknowledged.

Cantina Managed: 1-3 have been fixed, 4 has been acknowledged.